

Patient Privacy and HIPAA Compliance

Protecting Patient Data and Health Information

Regulation: 45 CFR Parts 160 & 164 | 42 CFR §482.13(d)

POLICY OVERVIEW

The Health Insurance Portability and Accountability Act (HIPAA) establishes national standards for protecting individually identifiable health information. Hospitals must implement administrative, physical, and technical safeguards to ensure the confidentiality, integrity, and availability of Protected Health Information (PHI).

KEY REQUIREMENTS

1 Notice of Privacy Practices

Hospitals must provide patients with a Notice of Privacy Practices (NPP) at first contact, post the NPP prominently, and make good-faith efforts to obtain written acknowledgment of receipt from patients.

2 Minimum Necessary Standard

Staff may only access PHI that is necessary to perform their job functions. Role-based access controls must be implemented and enforced. Accessing records of patients not under one's direct care (including celebrity or VIP patients) is a violation.

3 Patient Access Rights

Patients have the right to: access and obtain copies of their health records, request amendments, receive an accounting of disclosures, request restrictions on certain disclosures, and request confidential communications.

4 Breach Notification

Any breach of unsecured PHI must be reported to affected individuals within 60 days of discovery, to HHS annually (or immediately for breaches affecting 500+ individuals), and to media for large breaches affecting the local community.

5 Technical Safeguards

Electronic PHI (ePHI) must be protected through: access controls, audit logs, encryption, automatic logoff, integrity controls, and transmission security. Mobile devices with ePHI must be encrypted and remotely wipeable.

COMPLIANCE NOTES

HIPAA violations can result in civil penalties ranging from \$137 to \$2,067,813 per violation category per year. Criminal penalties may apply for intentional violations. A Privacy Officer and Security Officer must be designated.

COMMON SURVEY CITATIONS

Cited under 45 CFR §164.502 – Uses and disclosures of PHI, §164.524 – Access of individuals to PHI, and §164.400-414 – Breach notification.